



Chapter 15: Risk Management & Cryptography

CompTIA Security+ Study Slides

Walailak University — Assist. Prof. Dr. CJ

Learning Objectives

- Understand **risk management principles and frameworks**
- Conduct **risk assessment** and apply mitigation strategies
- Identify **encryption algorithms** and their applications
- Explain **hashing, digital signatures, and certificates**
- Understand **PKI components** and key management

Introduction

Cybersecurity is a balance between **risk and control**.

Goal:

- Identify risks → Evaluate impact → Mitigate effectively

Risk Management = the ongoing process of identifying, analyzing, and reducing threats to acceptable levels.

The Risk Management Process

1. **Identify** assets, threats, and vulnerabilities
2. **Assess** likelihood and impact of each risk
3. **Prioritize** based on business objectives
4. **Mitigate** using controls (technical, physical, administrative)
5. **Monitor** and **review** continuously

 Frameworks: NIST RMF, ISO 27005, ISO 31000



Risk Concepts

Term	Definition
Threat	Potential cause of unwanted incident
Vulnerability	Weakness exploited by threat
Risk	Likelihood × Impact of a threat exploiting a vulnerability
Exposure	Condition of being susceptible to loss
Residual Risk	Remaining risk after controls applied



Risk = Threat × Vulnerability × Asset Value

Risk Assessment Types

Type	Description
Qualitative	Uses descriptive scales (low, medium, high)
Quantitative	Uses numeric metrics (dollars, probability)
Hybrid	Combines both approaches

Quantitative Example:

- **SLE (Single Loss Expectancy)** = Asset Value × Exposure Factor
- **ARO (Annualized Rate of Occurrence)** = frequency per year
- **ALE (Annualized Loss Expectancy)** = SLE × ARO

Risk Mitigation Strategies

Strategy	Description
Avoidance	Eliminate activity that causes risk
Transference	Shift risk to third party (insurance, outsourcing)
Mitigation	Apply controls to reduce risk
Acceptance	Acknowledge and monitor residual risk

 Always document the justification for accepted risks.

Security Controls

Control Type	Examples
Administrative	Policies, training, procedures
Technical	Firewalls, encryption, IDS/IPS
Physical	Locks, cameras, guards
Preventive	Stop incidents before they occur
Detective	Identify incidents (SIEM, logs)
Corrective	Restore after incident (backup, patch)
Compensating	Alternative when primary control not feasible

Risk Management Frameworks

NIST RMF (SP 800-37):

1. Categorize
2. Select
3. Implement
4. Assess
5. Authorize
6. Monitor

ISO 27001/27005:

Focus on **Information Security Management Systems (ISMS)** and continuous improvement.

Business Impact Analysis (BIA)

Purpose: identify critical business processes and the impact of their disruption.

Key Metrics:

- **RTO (Recovery Time Objective):** acceptable downtime
- **RPO (Recovery Point Objective):** acceptable data loss
- **MTBF (Mean Time Between Failures)**
- **MTTR (Mean Time To Repair)**

 Supports planning for disaster recovery and business continuity.

Introduction to Cryptography

Cryptography: science of protecting information by transforming it into unreadable form.

Function	Purpose
Confidentiality	Keep data private (encryption)
Integrity	Ensure data not altered (hashing)
Authentication	Verify identity (digital signature)
Non-Repudiation	Prevent denial of actions

 Cryptography underpins all digital trust.



Encryption Concepts

- **Plaintext:** original readable data
- **Ciphertext:** encrypted output
- **Algorithm:** mathematical formula for encryption
- **Key:** secret value that enables decryption
- **Cipher Suite:** combination of algorithms used in TLS/SSL

Two major types:

- **Symmetric (same key)**
- **Asymmetric (public/private key pair)**

Symmetric Encryption

- Uses **one key** for both encryption and decryption
- Fast and efficient for large data volumes

Examples:

- **AES (Advanced Encryption Standard)** – 128/192/256-bit
- **3DES (Triple DES)** – legacy, less secure
- **Blowfish / Twofish** – variable-length block ciphers

 AES-256 is the modern standard for secure data at rest.

Asymmetric Encryption

- Uses **two keys**: public and private
- Enables secure key exchange and digital signatures

Algorithm	Description
RSA	Most common public-key system; strong but slower
ECC (Elliptic Curve Cryptography)	Smaller keys, faster, ideal for mobile devices
Diffie–Hellman (DH)	Used for secure key exchange
ElGamal	Asymmetric encryption based on DH



Used in HTTPS (TLS), email encryption, and PKI certificates.

Hashing Functions

Purpose: verify data integrity; produces a unique fixed-length output.

Examples:

- **MD5** – legacy, insecure
- **SHA-1** – deprecated
- **SHA-256 / SHA-3** – current secure standards

Properties:

- One-way function
- Deterministic output
- Collision-resistant



Used for digital signatures, file verification, password hashing.

HMAC – Hash-Based Message Authentication Code

- Combines a **shared secret key** with a hash function
- Provides both integrity and authentication
- Used in **TLS**, **IPsec**, and **API authentication**

Formula: $\text{HMAC} = \text{Hash}(\text{Key} + \text{Message} + \text{Key})$

Digital Signatures

Purpose: verify sender authenticity and message integrity.

Process:

1. Hash the message
2. Encrypt the hash with the sender's **private key**
3. Recipient decrypts with **public key** to verify

Provides:

-  Integrity
-  Authentication
-  Non-repudiation

 Commonly used in code signing, SSL certificates, and email encryption.

Public Key Infrastructure (PKI)

PKI: framework that manages digital certificates and public keys.

Core Components:

- **CA (Certificate Authority)** – issues and signs certificates
- **RA (Registration Authority)** – verifies user identity
- **CSR (Certificate Signing Request)** – sent by applicant to CA
- **CRL / OCSP** – verify revocation status

 PKI = trust model for secure digital communication.

Certificate Types

Type	Purpose	Example
Root Certificate	Trusted anchor for the PKI hierarchy	Root CA
Intermediate Certificate	Subordinate CA for scalability	Issuing CA
End-Entity Certificate	Issued to users, servers, or devices	SSL/TLS, Email, Code Signing
Wildcard Certificate	Covers multiple subdomains	*.example.com
SAN Certificate	Supports multiple domain names	example.com, example.org

Certificate Lifecycle

1. **Request** (CSR submission)
2. **Issuance** (CA verification and signing)
3. **Installation** (on server or device)
4. **Renewal** (before expiration)
5. **Revocation** (if compromised)
6. **Expiration** (auto invalidation after period)

 Proper lifecycle management prevents trust compromise.

Key Management Best Practices

- Generate strong, random keys
- Store keys in secure hardware (HSM, TPM)
- Rotate and revoke compromised keys immediately
- Limit access to private keys
- Maintain backup copies under dual control
- Implement logging and auditing

 *Key security = encryption security.*

Cryptographic Protocols

Protocol	Purpose	Example
TLS/SSL	Web and email encryption	HTTPS, SMTPS
IPsec	Secure network traffic	VPN tunnels
SSH	Secure remote access	SFTP, SCP
PGP/GPG	Email and file encryption	Encrypted communications
S/MIME	Secure email exchange	Signed/encrypted emails



Emerging Cryptography

- **Quantum-Resistant Algorithms:** post-quantum encryption research
- **Homomorphic Encryption:** computation on encrypted data
- **Blockchain & Digital Certificates:** distributed trust models
- **Zero-Knowledge Proofs:** verify truth without revealing secrets



Stay updated: cryptography evolves rapidly with computing power.

Best Practices Summary

- Identify and assess risk systematically
- Implement appropriate mitigation controls
- Use **AES** for symmetric and **RSA/ECC** for asymmetric encryption
- Secure key management and PKI lifecycle
- Monitor, audit, and adapt to new cryptographic threats

End of Chapter 15

 **Course Complete — Cybersecurity Fundamentals: CompTIA Security+**